VulnSuite

Assessment and detection

- Code, dependencies and infrastructure assessment
- Linux and Windows security telemetry
- Malware signals and cross-host correlation

Security operations

- Verified identity, roles and a shared SOC view
- Incident ownership and central agent enrollment
- Reviewed quarantine, isolation and cloud-WAF response

Implemented source with automated validation | Production rollout requires deployment-specific staging.

What the suite addresses

Reduce exposure

- Find vulnerable software and unsafe configurations
- Assess exposed services, APIs and TLS settings
- Prioritise findings using severity and asset context

Investigate and respond

- Connect host alerts with vulnerability findings
- Assign incidents, review evidence and track action
- Approve bounded containment and inspect receipts

Selected detection signals support investigation; this release does not claim complete EDR coverage.

Platform coverage

Assessment modules

- SCA, secrets and static code analysis
- Network, cloud, containers and asset discovery
- IaC, Kubernetes and external attack surface
- API testing and software supply-chain checks

Protection and operations

- Linux audit and Windows event adapters
- Access, process, malware and integrity signals
- SOC console, investigations and agent lifecycle
- Signed notifications and approved response plans

Assessment and protection services retain separate persistence and deployment boundaries.

Software and supply-chain risk

Code and dependencies

- Trivy, pip-audit and OSV-Scanner collectors
- Semgrep and Bandit static analysis
- Gitleaks and TruffleHog secret detection

Build and artifact evidence

- Syft software bill of materials
- Cosign signature and attestation checks
- VEX statements captured in finding evidence
- Risk scoring and remediation lifecycle tracking

Coverage depends on configured targets, installed tools and available advisory data.

Infrastructure and API assessment

Infrastructure

- Nmap service discovery and testssl.sh TLS checks
- Prowler cloud configuration collectors
- Checkov / Trivy IaC and Kubernetes posture checks

Applications and APIs

- Nuclei and OWASP ZAP assessment collectors
- Target allowlists and active-scan configuration gates
- External discovery with Subfinder and httpx

Assessment scans complement host monitoring and inline WAF enforcement.

Verified identity and access

Authentication and roles

- Verify token signature, issuer, audience and expiry
- Require signed tenant and explicit role claims
- Separate viewer, auditor, analyst and admin rights
- Use external identity-provider sign-in and MFA

Tenant and approval boundaries

- Bind assessment transactions to signed tenant ID
- Enforce PostgreSQL row-level security policies
- Bind protection access to one organisation
- Require a different admin to approve playbooks

JWT verification and RLS controls are implemented; live IdP integration and database-role enforcement need staging.

Unified operations console

Shared investigation view

- View intrusion alerts and vulnerability findings
- Inspect agent health, sensor status and version drift
- Create and assign incidents from selected alerts
- Review response plans before approval

Operational safeguards

- Apply the same API role checks to console actions
- Keep access tokens in browser-tab memory
- Report unavailable upstream sources explicitly
- Retrieve findings through a fixed HTTPS connector

The console shows bounded recent lists; it is not an exhaustive cross-platform evidence search.

Broader endpoint telemetry

Windows monitoring

- Security log authentication and network logons
- RDP and SMB evidence where source events support it
- Sysmon process-creation records
- Selected fields without raw command-line capture

Linux monitoring

- Event-driven audit execution records
- Existing /proc process polling as a complement
- SSH access, API denials and file-integrity signals
- Sensor health and missing-telemetry indicators

Windows now includes monitoring and approved quarantine, restoration, host isolation and release. Native Windows staging validation is still required.

Process and malware detection

Suspicious activity

- Recognised web-server parent spawning a shell
- Execution from writable temporary locations
- Deleted executable signals on Linux
- Event-driven records improve short-process visibility

Malware evidence

- Known-bad SHA256 matches on selected targets
- Optional ClamAV scans of selected local files
- Path, signature and hash retained for review
- Unavailable scanners surface degraded coverage

No complete memory scanning, full-disk protection or automatic process-termination claim is made.

Lateral-movement signals

Correlated patterns

- Password spraying across multiple hosts
- Same-user successful-login fan-out
- Suspected pivots from already flagged hosts
- Remote-access evidence from supported event sources

Investigation context

- Administrator-defined host-to-IP ownership
- Time-bounded correlation with retained evidence
- Retry, out-of-order and restart handling
- Expiring exceptions for reviewed false positives

NAT, shared accounts and legitimate automation need review; protocol labels require supporting source evidence.

WAF integration

On-premises or proxy WAF

- Nginx / ModSecurity and OWASP CRS templates
- Sanitised serial-JSON rule-match collection
- DetectionOnly starting configuration
- No request-body or credential export

Cloudflare response connector

- Use a configured zone and custom-ruleset scope
- Apply an approved source-IP block
- Embed fixed expiry in the provider rule
- Retry cleanup without extending the deadline

Rule ordering, provider permissions, propagation and real traffic enforcement remain staging checks.

Reviewed local containment

Quarantine and restoration

- Use approved malware path and SHA256 evidence
- Linux: private same-filesystem quarantine vault
- Windows: file-handle checks and protected ACLs
- Restore without overwriting existing files

Isolation and release

- Require separate approval and local policy
- Linux: kernel-expiring nftables isolation
- Windows: firewall rules with local recovery tasks
- Preserve configured management access

Windows expiry uses local recovery tasks; Linux uses kernel timeouts. Native enforcement and recovery require staging.

How the components fit

Assessment service

- Scanner collectors and orchestration workers
- Canonical findings and deterministic risk scoring
- Verified API access and PostgreSQL tenant policies
- Read-only findings feed into the operations console

Protection service

- Authenticated Linux and Windows agents
- One organisation per SQLite operational store
- Detection, incidents, policies and response history
- Independent delivery and cloud-response worker

SQLite protection persistence is not a horizontally scalable or highly available PostgreSQL backend.

Central agent lifecycle

Credential management

- Issue expiring, one-time enrollment credentials
- Store hashes of enrolled host credentials
- Rotate keys and revoke agent access centrally
- Cancel unexecuted responses after revocation

Inventory and policy

- Track platform, agent version and queue health
- Record administrator policy-version history
- Flag drift from the desired software version
- Keep privileged response enablement local to hosts

Agent software upgrades use an administrator-controlled rollout; this release does not remotely execute upgrades.

Incident and notification workflows

Investigation workflow

- Link alerts to owned incident cases
- Track status, notes and evidence timelines
- Protect concurrent edits with case versions
- Review alerts and add scoped, expiring exceptions

SIEM and ticketing bridges

- Send signed JSON to fixed HTTPS endpoints
- Persist delivery state, leases and retry attempts
- Attach stable keys for receiver deduplication
- Audit outcomes without storing upstream secrets

Webhooks support organisation-operated adapters; native Jira, ServiceNow or Splunk connectors are not implied.

Reliable delivery and retention

Telemetry continuity

- Keep events until exact acknowledgement
- Replay retained events after service outages
- Pause collection visibly when the queue is full
- Archive older events without fresh containment

Evidence maintenance

- Create consistent SQLite backups and verify restore
- Preview retention cleanup before applying it
- Preserve incident and response-linked evidence
- Create offline-agent and stale-sensor alerts

Schedule maintenance explicitly and measure capacity, recovery objectives and backup security in the target environment.

Implementation validation

Security and protection tests

- Signed-token rejection, roles and tenant controls
- Enrollment, revocation and case concurrency
- Windows/audit parsing and outage handling
- Durable notification retries and retention behavior

Workflow validation

- Separate-actor approval through execution receipt
- Linux/Windows quarantine and restore workflows
- Mocked cloud-WAF expiry, cleanup and revocation
- Console interaction and synthetic detector scenarios

Automated security/protection and end-to-end tests exercise code paths; mocked enforcement does not establish live efficacy.

Required staging validation

Identity and host environment

- External identity-provider issuance and revocation
- PostgreSQL RLS with the deployed runtime role
- Windows Security/Sysmon and Linux audit collection
- ClamAV installation, signatures and scan results

Enforcement and workload

- Cloudflare permissions, expiry and rule ordering
- ModSecurity / CRS tuning and real intervention
- Linux/Windows isolation, expiry and rollback
- False positives, overhead, backlog and recovery

No production IdP changes, external notifications, cloud-WAF rules or live host firewall changes were made here.

Further enhancement opportunities

Scale and endpoint depth

- Benchmark real organisation workloads
- Design operational HA and enterprise persistence
- Extend process, memory and network visibility
- Validate Windows fleet coverage and recovery

Integration and rollout maturity

- Add provider-specific WAF and ticket adapters
- Expand labelled detection evaluation datasets
- Strengthen signed-package upgrade orchestration
- Measure production coverage and response quality

These are future extensions; central enrollment, verified access, the SOC console and reviewed playbooks are now implemented.

Proposed 30-day pilot

Weeks 1–2: establish coverage

- Confirm owners, asset scope and identity integration
- Enroll selected Linux and Windows staging hosts
- Enable native audit sources and stage the WAF
- Baseline normal activity and review noisy signals

Weeks 3–4: validate and decide

- Exercise incident and signed-notification workflows
- Validate quarantine, isolation, expiry and rollback
- Test outage replay, retention and verified recovery
- Agree measurable production acceptance criteria

Pilot scope and dates are proposals; rollout follows evidence from staging and an approved operational runbook.